YIFEI SUN

Principal Java Engineer · Security Infrastructure, Identity & Distributed Systems · 13 Years

(617) 922-4823
sun1fei@gmail.com
linkedin.com/in/yifei-sun-a789861b

SUMMARY

Principal Java engineer with 13 years building secure, high-scale distributed systems and identity infrastructure. Architected and deployed production authentication and authorization platforms — designed Keycloak-based SSO with custom token validation plugins (OAuth 2.0, SAML), built API gateway security layers (Kong, Nginx) with RBAC enforcement and rate limiting, and established secure service-to-service communication via service mesh (Linkerd + mTLS on Kubernetes). Deep expertise in core Java (concurrency, JVM internals, performance tuning), high-volume API design (millions of daily requests, p99 <50ms, 99.9% availability), and cross-organizational technical leadership driving security and architecture standards across 10+ teams.

LEADERSHIP HIGHLIGHTS

- Built production auth & identity platform: Keycloak SSO, custom OAuth token validation in Kong API gateway (Python), unified auth across 3 platforms
- Deployed service mesh (Linkerd + Kong on K8s) with secure service-to-service communication, custom rate limiting, and traffic management
- Led cross-team API redesign: p99 5× reduction, 99.9% availability, secure microservices on Kubernetes with fault isolation and circuit breaking
- Drove security and architecture standards across 10+ teams, 3 departments via RFCs, design docs, and engineering training sessions

Technologies: Core Java (Collections, Streams, Concurrency, JVM tuning), Spring Boot, Python, Node.js · **Security:** OAuth 2.0, SAML, Keycloak, JWT/token validation, RBAC/ABAC, Kong, Nginx · **Infrastructure:** AWS (ECS, EKS, SQS, SNS, S3, RDS, DynamoDB), Terraform, Ansible · Kubernetes, Docker, Linkerd (service mesh), Kafka, Redis, PostgreSQL, Cassandra · REST API, gRPC, GraphQL · Datadog, Grafana, Distributed Tracing · CI/CD

EXPERIENCE

CarGurus — Principal Software Engineer / Technical Lead

Oct 2019 – Present

High-Volume API Platform — Secure Microservices Architecture

- Led 3 principal/senior engineers and partnered with ~10 teams across 3 departments to redesign the core API behind CarGurus' most-visited page (~8,000 rpm, millions of daily impressions), migrating from monolith to Kubernetes-orchestrated microservices with per-service authentication, fault isolation, and circuit breaking.
- Architected orchestration service consolidating 12 downstream integrations into 5 well-defined services with idempotent retry, secure service-to-service contracts, and strict authorization boundaries between domains.
- Built automated parity-testing infrastructure comparing new vs. legacy responses at 50% production traffic — correctness verification at scale ensuring zero data integrity regressions during migration.

  p99: 250 ms → 50 ms (5×) **Availability: 98% → 99.9%** **Deploy: 1 hr → 3 min** (20×)
- Defined platform-wide security and observability standards: structured logging, distributed tracing (Datadog), SLO-based latency budgets, and audit trail requirements per downstream dependency.

GraphQL Federation — Secure Multi-Consumer API Layer

- Designed and integrated a Netflix DGS subgraph into CarGurus' federated GraphQL gateway with per-consumer authorization, exposing vehicle data to frontend, backend, and AI consumers through a unified, access-controlled graph.
- Implemented schema federation, batch data loaders (N+1 prevention), and JVM warmup strategies to eliminate JIT compilation latency spikes on cold starts.

Event-Driven Platform — Secure Messaging on AWS

- Led backend platform design using event-driven architecture (SQS/SNS for async messaging, Kafka for event streaming) with Terraform-managed AWS infrastructure and IAM-based access controls per service.
- Built infrastructure for rapid product experimentation with security isolation — each product bet deployed in its own service boundary with independent auth and data access controls.

Cross-Org Architecture Standards & Technical Mentorship

- Established reusable patterns for API security, observability, caching, and distributed orchestration adopted across multiple teams; authored design docs, RFCs, and architecture decision records.

- Led 10+ training sessions for engineering teams. Mentored senior engineers on secure system design, API excellence, and path to Principal-level scope.

Applause — Senior Software Engineer / Technical Lead

Oct 2017 – Oct 2019

Authentication & Identity Platform — Keycloak SSO + API Gateway Security

- Architected and deployed a production identity platform: migrated legacy auth to Keycloak-based SSO (OAuth 2.0, SAML), unifying authentication across internal systems, an enterprise partner platform, and a large external community with role-based access control.
- Built custom token validation and authorization plugins for Kong API gateway in Python — enforcing per-request RBAC at the gateway layer, validating Keycloak-issued JWTs, and handling token refresh and session management.
- Deployed service mesh (Linkerd on Kubernetes) with mTLS for secure node-to-node communication. Performed Glassfish-to-modern-runtime migration with JVM memory management and concurrency tuning.
- Migrated multiple Java and Node.js services behind the new auth gateway with minimal downtime, coordinating across 4 teams to ensure consistent security posture.

Event Sourcing & Microservices Architecture

- Drove design and prototyping of microservice architecture based on event sourcing and CQRS; defined foundational security and data isolation patterns for services, events, and read/write models.

Toast Inc. — Senior Software Engineer

Sep 2014 – Oct 2017

Core Platform Services & API Gateway Security

- Among the earliest engineers during hypergrowth; built core platform services end-to-end (Order Service, Labor Service, REST APIs) with authentication, authorization, and input validation at every service boundary.
- Built a custom API gateway in Nginx with Lua scripting for rate limiting, request authentication, traffic routing, and abuse prevention — handling all external API traffic before a dedicated security team existed.
- Set up the initial AWS environment using Ansible — provisioned infrastructure, deployment pipelines, IAM policies, and monitoring. Created the first automated testing framework for safe releases.

Third-Party Platform Integrations

- Led secure API integrations with key partners (workforce management), designing authenticated bidirectional sync with schema validation and access control. Partnered with PMs and support to translate requirements into secure platform capabilities.

The MathWorks Inc. — Software Engineer II

Jul 2013 – Aug 2014

Developed internal engineering tools (Java backend) for MATLAB/Simulink workflows. Improved backend automation systems for build/test reliability and developer productivity.

EDUCATION

M.S. in Electrical and Computer Engineering — Northeastern University, Boston 2010 – 2013

B.S. in Information Science — Beijing University of Aeronautics and Astronautics 2006 – 2010